exposing raw tokens outside the enforcement tier or requiring posture checks on customer tenants.

## 13.4 Designing for externalized authorization

With the identity and tenancy foundations in place, ACME's next challenge was operational: how to shift authorization decisions from code to a unified, policy-driven workflow. The goal was to externalize authorization while keeping it invisible. Policies should decide the outcome, but applications shouldn't need to know anything about Cedar or policy evaluation.

In the internal Customer Collaboration platform, every service decided access locally. Now, in C³, the Policy Enforcement Point (PEP) acts as the broker between the application and the policy engine. The PEP verifies incoming tokens, collects contextual data, and sends a normalized authorization request to a Policy Decision Point (PDP).

Each request contains four key elements—principal, action, resource, and context—the same components introduced in the PARC model in Chapter 7. These elements together describe the "who, what, and under what conditions" of every authorization decision. They're summarized in Table 13.1.

**Table 13.1 Elements of a C³ authorization request**

| Element | Example | Description / Source |
|---|---|---|
| principal | `C3::CustomerUser::"t-412:alex"` | The identity performing the action, derived from the OIDC token and mapped to a Cedar entity |
| action | `C3::"doc:share"` | The operation being attempted, inferred from the API route or function call |
| resource | `C3::Document::"doc-981"` | The target object of the request, identified by its canonical ID |
| context | `tenant_id: "t-412", device_posture: "compliant", risk_score: 0.14` | Environmental information assembled by the PEP, including tenant, device posture (for ACME employees), and other runtime signals |